

AI-Based Phishing Detection & Risk Assessment SOC Assistant

A Privacy-Safe, Hybrid Machine Learning Pipeline for Automated Email Triage

Daniel Shatzov • Ori Geva

Course: AI in Cybersecurity based on NVIDIA Morpheus

1. PROBLEM STATEMENT & OPERATIONAL NEEDS

Security Operations Centers (SOCs) face an unceasing influx of suspicious email notifications. This heavy volume drives severe analyst alert fatigue and delays triage response windows, increasing organizational window-of-exposure risks [cite: x].

Core Objective: Develop an automated, lightweight decision-support assistant running sub-second workflows to identify threat indicators, establish threat mapping alignments, evaluate composite risks, and generate immediate response advice [cite: x].

2. ARCHITECTURAL SAFETY & PRIVACY GUARDRAILS

- **100% Local Execution:** Runs completely independent of cloud-based APIs or third-party LLM access tokens, removing operational overhead, external network lag, and sensitive data exposure vulnerabilities [cite: x].
- **Privacy-First Data Auditing:** Absolute system restriction against writing or committing raw email headers, subject lines, or message bodies to local log storage [cite: x].
- **Advisory Decision Support:** Functions strictly as an analyst assistant; automated destructive pipeline modifications (e.g., live mailbox changes or blocking rules) are strictly locked away from standalone machine execution [cite: x].

3. DATASET ENGINEERING & REPRODUCIBILITY

Utilizes the standalone **CEAS_08 Phishing Email Dataset** from Kaggle, isolated via deterministic script automation to maximize training configuration reproducibility [cite: x].

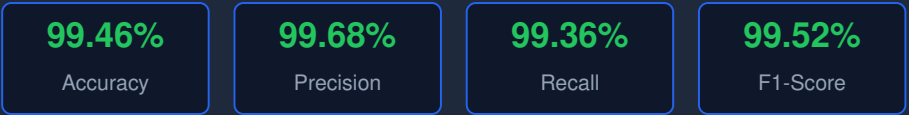
- **Volume Matrix:** Preprocessing cleans 39,154 raw elements down to 39,085 fully clean rows by handling formatting anomalies [cite: x].
- **Feature Engineering:** Strips characters, builds length vectors for fields, and constructs a balanced joint string field merging text variables [cite: x].
- **Git Isolation:** All raw text metrics, local compiled model binaries, and live audit trails are omitted via version rules to maintain code-base isolation [cite: x].

data/raw/CEAS_08.csv → src/preprocessing.py → data/processed/ceas08_clean.csv → src/train_baseline.py → models/phishing_baseline.joblib

4. EXPLANATORY MACHINE LEARNING ENGINE

To optimize execution overhead and provide mathematical clarity to Tier-1 analysts, a traditional machine learning design was selected over dense neural structures [cite: x].

- **Vectorization:** TfidfVectorizer maps text into a sparse frequency array, highlighting tokens that correlate with malicious intents [cite: x].
- **Classification:** Logistic Regression runs inference in milliseconds while preserving direct transparency through trace weights [cite: x].



Local Evaluation Confusion Matrix:

```
[[3439  14]  <-- [True Negatives (Benign) | False Positives]
[  28 4336]] <-- [False Negatives (Missed) | True Positives]
```

Why a Hybrid Core is Imperative
While statistical evaluation remains exceptionally high, the model missed 28 active attacks (False Negatives) [cite: x]. To mitigate the danger of a bypassed filter, our architecture implements rule-based heuristic indicator validation to catch payloads even if the model's text weights fail [cite: x].

5. SEQUENTIAL PIPELINE ORCHESTRATION

Managed natively by a single coordinator engine inside src/pipeline.py, incoming queries act as state-free events passing down an unyielding linear logic track [cite: x]:

Inbound Email Input → String Normalization → Machine Learning Prediction → Heuristic IoC Scans → MITRE Tactic Maps → Risk Score Tiers → Compliance Logging → Streamlit UI Presentation

6. CYBER THREAT ENRICHMENT & RISK TIERS

Our rule engine runs independent regex filters to build real-time cyber context across multi-tiered risk metrics [cite: x]:

- **Deterministic IoC Scans:** Tracks embedded URLs, top domains, raw IP addresses, financial phrases, and urgent keywords [cite: x].
- **Evidence-Backed MITRE Mapping:**

T1566.002 Spearphishing Link

T1566.001 Spearphishing Attachment

T1056.003 Input Capture

T1204.001 User Execution
- **Risk Scoring Engine (0-100):** Combines ML outputs with indicator densities to group incidents into actionable tactical bands [cite: x]:

0-24 Low

25-49 Medium

50-74 High

75-100 Critical

7. INTERACTIVE WORKSPACE & COMPLIANCE LOG

- **Streamlit Dashboard (dashboard/app.py):** Features manual entry modules alongside a pre-built catalog of 20 safe evaluation scenarios (10 benign corporate notifications and 10 phishing models) [cite: x].
- **Privacy Logging:** Writes safe JSON telemetry to disk using cryptographic SHA256 string signatures and numerical tracking lengths [cite: x].
- **Testing Coverage:** Fully validated across 33 passed pytest modules verifying edge metrics and pipeline outputs [cite: x].

8. NVIDIA MORPHEUS ALIGNMENT & CONCLUSIONS

Morpheus Paradigm: Although running as a lightweight local system, our project directly implements the pipeline-based cyber defense pattern introduced in the NVIDIA Morpheus framework—handling raw inputs as streams to enrich, score, and output SOC-ready alerts [cite: x].

Course Lab Reuse Matrix: Lab 2 inspired dataset processing and stratified valuation; Lab 3 structured indicator arrays and scoring; Lab 1 guided CTI taxonomy; Labs 4/5 established dashboarding, logging loops, and pipeline workflow [cite: x].

Conclusion: Emphasizes that joining highly interpretable machine learning structures with rule-based heuristics creates an efficient, robust, and completely privacy-safe automated assistant for high-throughput security environments [cite: x].